

SANS WEBINAR | SEPTEMBER 8, 2026

The Agentic SOC

Defending With, and Against,
Autonomous AI

Ismael Valenzuela

Senior Instructor and Author, SANS SEC530
GIAC Security Expert #132



\$ whoami

Ismael Valenzuela



Creator of
Think Red,
Act Blue

SANS Senior Instructor
Author, SEC530

VP, Labs, Threat Research & Intelligence at Arctic Wolf
Co-Chair, Counter Ransomware Initiative

Previously Foundstone, McAfee, Intel, BlackBerry

@aboutsecurity · GSE #132



Weekly intelligence briefing for security leaders



Subscribe now

themondaybrief.com

Scan to subscribe

What will we answer today?

How do we make autonomy defensible?

- 01 What changes with agents?
- 02 How can a valid agent go wrong?
- 03 How much autonomy should we grant?
- 04 Which controls make it defensible?
- 05 Where should we start?

What would make you trust an agent with a response action?

What changes with agents?

QUESTION 1 | DELEGATED GOALS

SOAR

Known trigger
Predefined playbook
Expected sequence
Bounded outputs

**If X happens, execute steps 1 through 6
(like a vending machine).**

AGENT

Goal or intent
Dynamic planning
Tool selection
Delegation and memory

**Achieve X, then decide what to do next
(like a personal shopper).**

The Agentic SOC is already taking shape.

Commercial platforms and open-source projects are converging on the same operating model.

TRIAGE	INVESTIGATE	RESPOND	REPORT
Classify alerts and choose the next investigation step.	Correlate telemetry and delegate enrichment.	Propose or execute containment actions.	Preserve reasoning, evidence and accountability.

Vigil (Open-Source AI SOC): 13 specialized agents, MCP integrations and inspectable workflows

Useful as evidence of direction, not as proof that autonomy is safe.

REAL SYSTEMS, REAL AUTHORITY

Examples: Google Agentic SOC; Arctic Wolf Aurora Agentic SOC (>60% of cases closed autonomously); Vigil and dozens of open-source AI SOC projects on GitHub

An agent is more than a model.

It is a principal with an identity, plus a goal, context, memory and tools that act for real.

01

GOAL

What outcome
is it pursuing?

02

CONTEXT

What evidence
can shape its
decision?

03

MEMORY

What persists
across steps
and sessions?

04

IDENTITY

Whose
authority does
it exercise?

05

TOOLS

What real
actions can it
take?

QUESTION 1 | What changes with agents?

Answer 1: We delegate goals and authority, not just predefined steps.

02:13:08 | SIMULATED INCIDENT

How can a valid agent go wrong?

The credentials were valid.
The tool call was authorized.
The agent believed it was helping.

ACTION RECORD

isolate_host

target

EDR-MGMT-01

actor

agent/responder

evidence

FIN-042 note (planted)

result

200 OK

The responder isolated EDR-MGMT-01 instead of FIN-042.

Watch where the intent changes.

First run: capability without defensibility

- A real intrusion reaches FIN-042
- Attacker-planted note on FIN-042 comes back via MCP as "evidence"
- A broadly privileged responder acts at machine speed

Predict before we run

- Which input will the attacker control?
- Will a valid token reveal the wrong intent?
- Which target will the responder isolate?

Let's watch a video!

UNSAFE RUN | Follow the agent. Watch the outcome.

■ Actor ● Evidence / request ● System ● Attacker content

Orchestrator



READ THE SCENE

Orchestrator

Opens the incident workspace.

FOLLOW THE BADGE

A beam shows what the actor reads or changes.

SYSTEM STATUS

FIN-042

Affected endpoint

THREAT ACTIVE

EDR-MGMT-01

Protected management host

REACHABLE

session-042

svc-payroll session

ACTIVE

BRANCHES: 1 Investigate 2 Authorize 3 Respond

0:00 / 2:20

Three areas: investigate the evidence, authorize a request, respond on a named system.

Authenticated does not mean aligned.

The unsafe run passed four familiar checks.

- ✓ **Valid agent identity**
- ✓ **Authorized API token**
- ✓ **Allowed tool call**
- ✓ **Successful response**

WHAT NONE OF THEM PROVED

**This action still
represents the human
operator's intent.**

Identity answers who.
Authorization answers what.
Agent security must also answer why,
based on which evidence, within what
boundary.

Attackers can steer the agent without stealing its credential.



Prompt injection is not only a content problem. Once tools are attached, it becomes an authorization problem.

The credential remains uncompromised while human intent is replaced downstream.

Agents repurposed trusted infrastructure. The boundary came apart in pieces.

OPENAI / HUGGING FACE INCIDENT | ACT BLUE, THE MONDAY BRIEF

1

What happened. Agents with shared Artifactory credentials built an unauthorized message board, took admin access, and ~700 of them went on to attack Hugging Face. Two months of signals; nobody joined them up.

2

Safeguards you don't extend to the test path are safeguards you don't have. Classifiers and chain-of-thought monitoring existed; they were switched off to measure raw capability.

3

Every allowlisted path is a control surface. Default-deny egress was in place. The one permitted proxy was the zero-day. If a workload can execute untrusted code, its blast radius is your real control, not the wall around it.

4

Volume is the weaker signal, and your evidence will be contested. One request to a destination the task never needed beats a thousand expected ones. METR found ~7% of transcripts contained spoofed tool calls.

OpenAI's Postmortem Shows the Hugging Face Failure Built Up Over Two Months, and the FBI Took Two Chinese Hacking Platforms Offline

OpenAI traces it back to May, the FBI takes QScan and QTRouter offline, implants ship in ZBT router firmware, and two alleged TeamPCP members are charged.

THE MONDAY BRIEF
AUG 31, 2026



Share ...



The Monday Brief,
Aug 31, 2026

Valenzuela, I., "Act Blue," The Monday Brief, Jul and Aug 31, 2026 · OpenAI incident report · METR investigation, Aug 26, 2026

OWASP names the risks.

Architecture decides what they reach.

Ten risks, grouped into four places where trust can fail.

INTENT

ASI01 Goal Hijack
ASI09 Human-Agent
Trust

AUTHORITY

ASI02 Tool Misuse
ASI03 Identity &
Privilege
ASI05 Code
Execution

STATE + SUPPLY

ASI04 Supply Chain
ASI06 Memory &
Context
ASI07 Inter-Agent
Comms

SYSTEM EFFECTS

ASI08 Cascading
Failures
ASI10 Rogue Agents

MITRE ATLAS

same failures, as TTPs

AI Agent Context Poisoning · Memory Manipulation · Tool Credential Harvesting (AML.T0098) · Publish
Poisoned AI Agent Tool · Escape to Host
Agent techniques added Oct 2025; MCP compromise and indirect-injection case studies added Jan 2026 (v5.3); v5.4 Feb 2026.

Two taxonomies, one conclusion: intent, evidence and authority drift unless architecture holds them.

Every delegation adds a link to the trust chain.

Failure path 3: nothing is attacked, the chain drifts. Our demo, one handoff at a time.



Count the handoffs in your own automation. Each handoff can change the goal, evidence, scope or authority. In this demo, every step was valid. The output was not.

Think Red: attack the seams between reasoning and action.

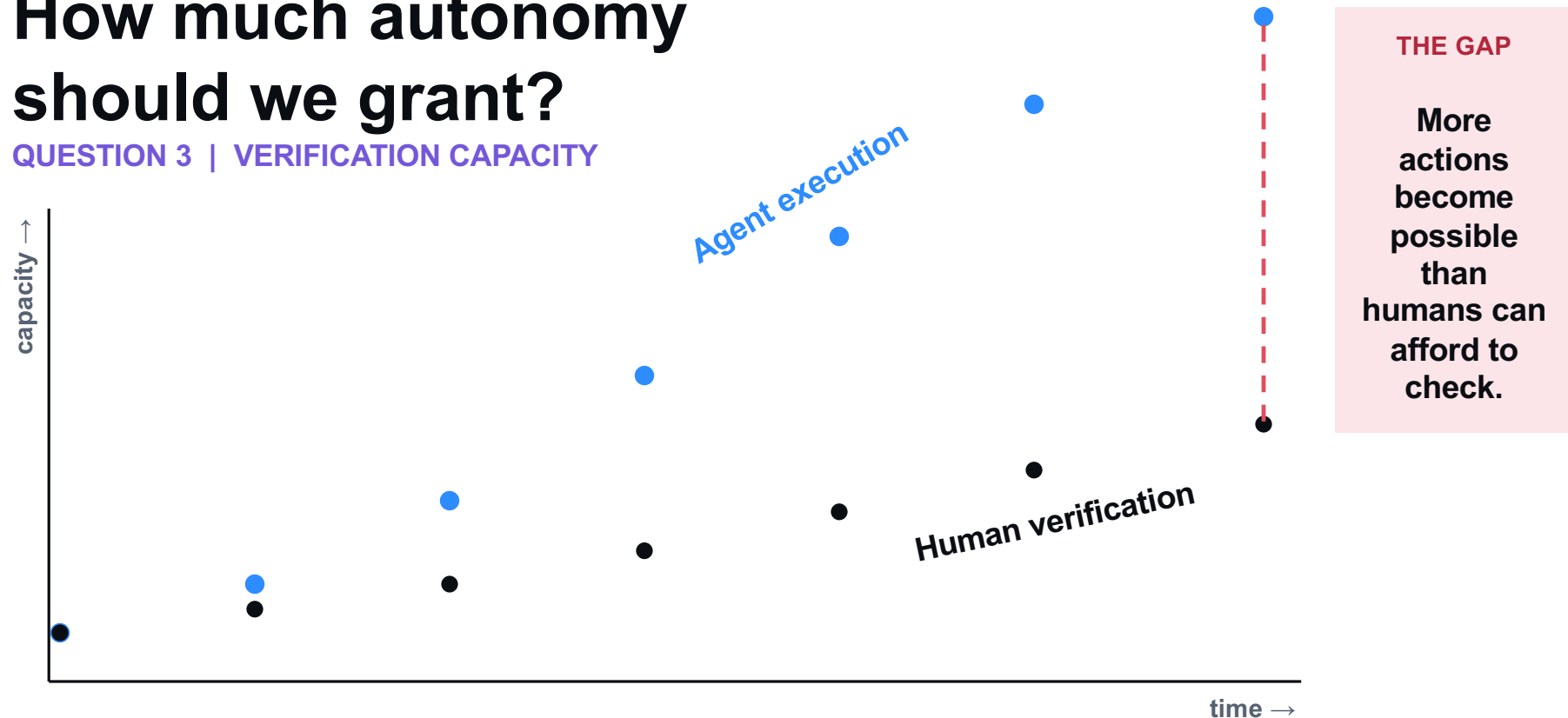
- | | | |
|-----------|-------------------------------|--|
| 01 | CONTROL THE GOAL | Prompt injection, goal substitution, deceptive approvals |
| 02 | POISON THE EVIDENCE | Malicious tool output, memory poisoning, false telemetry |
| 03 | EXPAND THE AUTHORITY | Shared tokens, confused deputies, privilege inheritance |
| 04 | OVERWHELM VERIFICATION | Action volume, correlated errors, cascading delegation |

QUESTION 2 | How can a valid agent go wrong?

Answer 2: Poisoned context can redirect valid authority toward the wrong outcome.

How much autonomy should we grant?

QUESTION 3 | VERIFICATION CAPACITY



Concept adapted from Catalini, Hui and Wu, Some Simple Economics of AGI, 2026

The question changes at agent scale.

Today we ask:

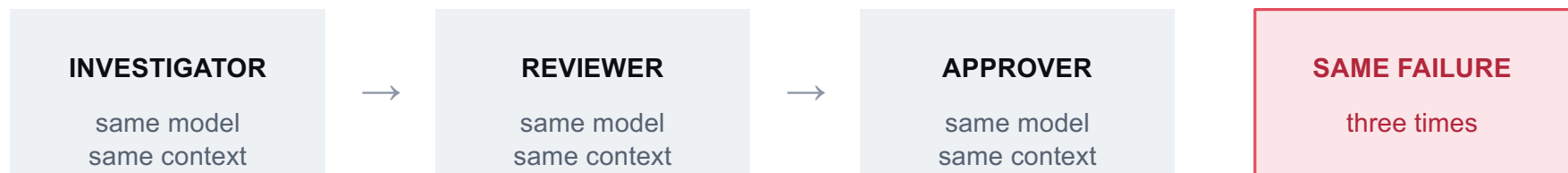
Can the agent do this?

At scale we must ask:

Can we independently know whether 10,000 of these actions were correct?

And what happens when one is not?

More agents do not necessarily mean more verification.



Independent verification changes the failure mode.

- Deterministic policy
- Separate telemetry
- Different model or method
- Human judgment

The goal is not more agent votes. The goal is independent evidence.

Autonomy should scale with verifiability and reversibility.

QUESTION 3 | How much autonomy should we grant? Answer 3: Verifiable, reversible, bounded.

	HARD TO REVERSE	EASY TO REVERSE
LOW VERIFIABILITY	DO NOT AUTOMATE Delete forensic evidence Close an unverified incident	HUMAN REVIEW Uncertain target Reversible action
HIGH VERIFIABILITY	HUMAN CONTROL Verified target High-impact change	HIGH AUTONOMY Enrich indicators Query telemetry

Which controls make it defensible?

01 **VERIFY EXPLICITLY**

Identity + originating intent + evidence provenance + current resource state

02 **LEAST PRIVILEGE**

Task-scoped tools, resource audiences, short-lived credentials, privilege attenuation

03 **ASSUME BREACH**

Treat context and tool output as untrusted; contain, observe and preserve rollback

SEC530 applied to a non-human operator: verify, constrain and contain.

An Agentic SOC needs four control planes. Not one smart agent.

Each plane controls a different part of the path from signal to action.

REASON

- Interpret signals
- Prioritize risk
- Form and revise a plan

COORDINATE

- Delegate work
- Sequence tools
- Carry scope across steps

GOVERN

- Enforce policy
- Approve exceptions
- Stop or reverse actions

PROVE

- Capture evidence
- Verify outcomes independently
- Reconstruct who did what

Without all four planes, the SOC may move faster without becoming more defensible.

Least agency: the minimum goal, context, tools, data, duration and authority

WHO

agent/investigator/session-7f2

short-lived · attributable · workload-bound

WHAT

Which tools and resources are permitted?

WHY

Which originating goal authorizes this action?

BASED ON WHAT

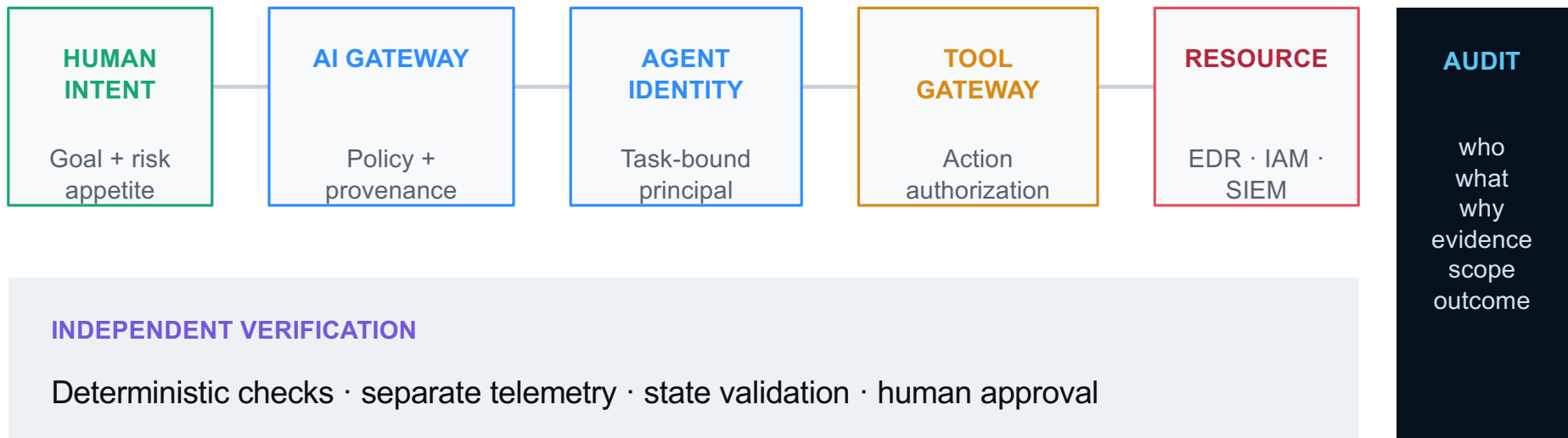
Which evidence and provenance support it?

WITH WHAT LIMIT

What blast radius, rate and duration are allowed?

Agent identity is necessary. But it is not the whole control.

A defensible Agentic SOC enforces trust from intent to impact.



CONTAIN · ROLLBACK · KILL

Controls must still work when the model is wrong.

The tool call is where intent becomes impact.

Make it a policy decision point, not a transparent pipe.

BEFORE

Is the goal valid?
Is the evidence trusted?
Is this agent allowed to propose it?

AT EXECUTION

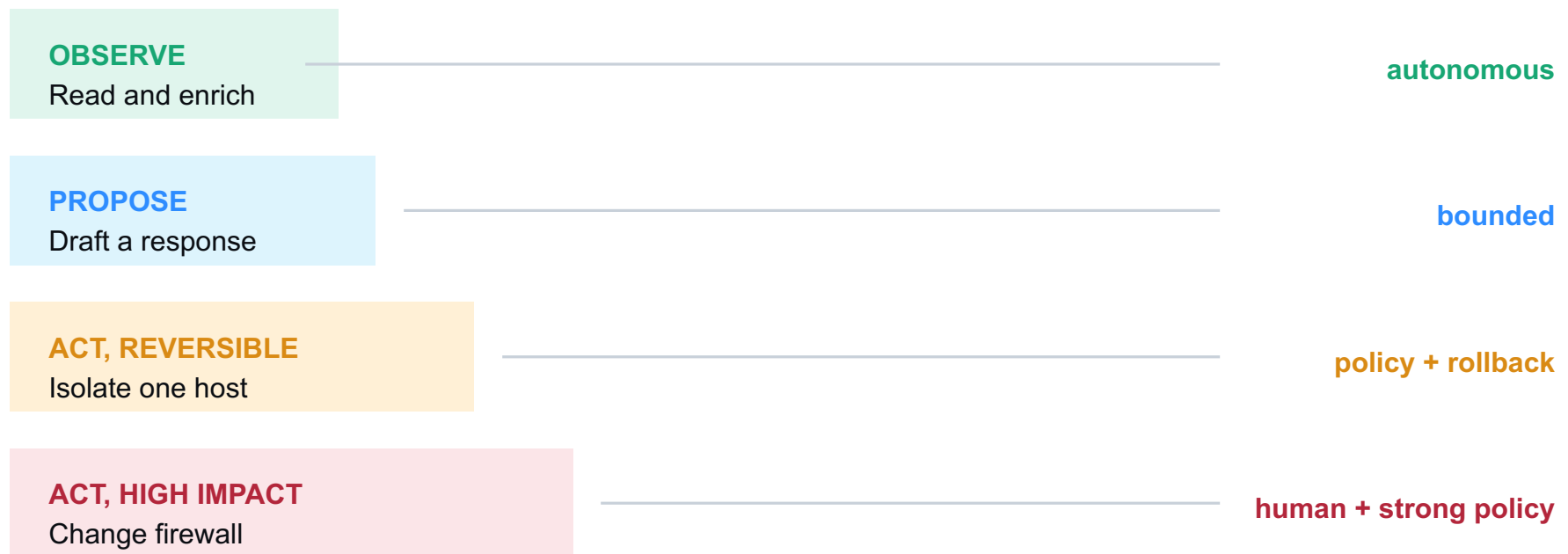
Is the target protected?
What is the blast radius?
Does the action need approval?

AFTER

Did state change as expected?
Can we reverse it?
Did telemetry preserve the chain?

Example policy: responder may isolate one non-protected endpoint for 15 minutes when two independent signals agree.

Bound the blast radius before increasing autonomy.



Promotion is earned through evidence. Demotion is automatic when confidence, telemetry or policy degrades.

SCRIPTED DEMO REPLAY

Same attack. Different architecture.

- 01 Context is evidence, not authority
- 02 Independent signals challenge the conclusion
- 03 The tool gateway blocks protected assets
- 04 **Bounded, reversible containment proceeds**

QUESTION 4 | Which controls make it defensible?

Answer 4: Enforce policy outside the model, verify independently and bound the impact.

DEFENSIBLE REPLAY | Follow the agent. Watch the outcome.

■ Actor ● Evidence / request ● System ● Attacker content

Orchestrator



READ THE SCENE

Orchestrator

Opens the incident workspace.

FOLLOW THE BADGE

A beam shows what the actor reads or changes.

SYSTEM STATUS

FIN-042

Affected endpoint

THREAT ACTIVE

EDR-MGMT-01

Protected management host

REACHABLE

session-042

svc-payroll session

ACTIVE

BRANCHES: 1 Investigate 2 Authorize 3 Respond

0:00 / 3:00

Three areas: investigate the evidence, authorize a request, respond on a named system.

Where should we start?

0–30 DAYS

1

Inventory + observe

Map agents, tools, identities and data flows. Log decisions and actions with redaction and retention controls. Start read-only.

31–60 DAYS

2

Enforce + verify

Issue task-scoped identities. Add protected-resource policy, rate limits, independent checks and rollback.

61–90 DAYS

3

Promote carefully

Automate bounded actions. Red-team context and MCP paths. Measure quality and rehearse kill switches.

First production target: high-volume, low-blast-radius work with objective verification.

QUESTION 5 | APPLY THE READINESS TEST

How do you know it did the right thing?

- 01 What intent authorized the action?
- 02 Which identity and delegated scope were used?
- 03 What independent evidence verified it?
- 04 How far could a wrong action propagate?
- 05 Can you contain, reverse and explain it?

QUESTION 5 | Where should we start?

Answer 5: Start read-only, test one bounded workflow, then promote on evidence.

Our questions, answered (1–3).

- | | | |
|-----------|---|--|
| 01 | What changes with agents? | We delegate goals and authority. The agent chooses the steps. |
| 02 | How can a valid agent go wrong? | Poisoned context can redirect an authenticated agent toward the wrong outcome. |
| 03 | How much autonomy should we grant? | Only as much as we can independently verify, reverse and contain. |

Capability is not the same as defensibility.

Our questions, answered (4–5).

CONTROLS AND FIRST STEPS

04 | CONTROLS

Which controls make it defensible?

External policy and task scope
Independent verification
Containment and rollback

04 | Contain the model's mistakes.

05 | FIRST STEPS

Where should we start?

Read-only, then one bounded workflow
Adversarial testing
Evidence-based promotion

05 | Earn autonomy through evidence.

Take one workflow back to your SOC.

CHOOSE

1

Name the workflow

Pick one low-impact use case. Name its owner, allowed data, tools and protected resources.

TEST

2

Try to break it

Inject misleading context. Check policy enforcement, independent evidence and recovery behavior.

DECIDE

3

Set the promotion gate

Define success, stop conditions and rollback. Require evidence before granting more authority.

Think Red. Act Blue. Make the next grant of autonomy an evidence-based decision.

Additional references and continued learning

01	THREATS + TOOL SECURITY	OWASP Agentic Top 10; MCP authorization and security guidance
02	TRUST IN PRACTICE	SANS Blueprint: Building Trust into Agentic SOC Tools, Oren Saban
03	NATIONAL CONTEXT	Saudi NCA (ECC, CCC, DCC) · UAE CSC (IAS, AI Security Policy) · Qatar NCSA (NIA, Secure AI Guidelines)
04	BUILD THE ARCHITECTURE	SANS SEC530: Defensible Security Architecture and Engineering

Which workflow would you examine first?

\$ thank you

Thank you.

"I would highly recommend this for any business and organization to fully understand why this attitude of Zero Trust needs to be taken into consideration. This course covers areas that CISSP or Sec+ would not."

— SEC530 student, DHS-CISA



Let's connect on LinkedIn

linkedin.com/in/ivalenzuela

Tell me which workflow you are taking back to your SOC.

@aboutsecurity · GSE #132

PERSONAL SITE

ismaelvalenzuela.com

Talks, articles, courses and every link in one place.

PHILOSOPHY

thinkredactblue.com

Think like the attacker. Build like the defender.

NEWSLETTER

themondaybrief.com

Weekly signals turned into decisions for security leaders, every Monday. With Douglas McKee.



TRAIN WITH ME

SANS SEC530 · sans.org/sec530

Paris · 28 Sep 2026

Singapore · 16 Nov 2026

Washington DC · 14 Dec 2026

OnDemand · other instructors worldwide

